

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>The data leak occurred because the principle of least privilege was not enforced. A manager granted a customer success representative access to an entire folder containing sensitive business plans instead of just the necessary marketing materials. Additionally, the manager failed to revoke this access, leading the representative to accidentally share the entire folder's link with an external partner.</i>
Review	<i>NIST SP 800-53: AC-6 focuses on the principle of least privilege, requiring organizations to grant users only the minimum access permissions necessary to perform their specific job functions. This control is essential to limit the potential damage from unauthorized access, accidental data leaks, or compromised user accounts.</i>

Recommendation(s)	• <i>Review of User Privileges (AC-6(7)):</i> Implement a routine schedule to audit and automatically revoke temporary access to sensitive folders once a task or project is completed. • <i>Restrict Access to Specific Files:</i> Configure the system to restrict sharing at the granular file level, preventing users from granting broad access to entire directories when only specific documents are required.
Justification	<i>Implementing routine reviews of user privileges ensures that temporary access is revoked promptly, preventing lingering unauthorized access. Furthermore, enforcing file-level sharing restrictions rather than broad folder access significantly minimizes the risk of accidental exposure of confidential internal documents during external communications.</i>

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.